



THE ARCHIVE
AND HERITAGE GROUP

✉ johan@theahg.co.za

🌐 <https://theahg.co.za>

☎ +27 87 265 5297

📍 490 Barry Hertzog Street
Constantia Park
Pretoria 0181

VAT:
4010321919

Reg No:
2024 / 316608 / 07

Framework: AI for Records/Archives Management

AI RAM Framework

Author: Johannes J. Pieterse

Date: 2026-06-20





CONTENTS

Authorship and usage.....	3
1. Executive summary.....	4
2. Purpose and scope.....	5
3. Core principles.....	5
4. Architecture (industry view).....	7
5. Key components and capabilities.....	9
1. Crawler & Ingest.....	9
2. OCR & Text Extraction.....	10
3. NER / Classification.....	10
4. Sensitivity Detection & Privacy.....	11
5. Provenance Store & Event Sourcing.....	12
6. Human Review & Workflows.....	12
7. APIs & Integration.....	13
6. Governance & roles.....	13
7. Implementation roadmap (MVP → Production).....	14
8. Minimum viable deployment checklist (for procurement/ops).....	16
9. Metrics & KPIs (suggested).....	16
10. Checklist for publishable industry artefact.....	17
Annextures.....	18
A.1 Annexure: Mapping to standards & statutes (short).....	18
A.2 Annexure: AI RAM Framework – API / JSON-LD / provenance / PROV-O.....	19
A.3 Annexure: AI RAM Framework - Jurisdiction-agnostic Template and Checklist	23
A.4 Annexure: Regime-specific templates.....	26
A.5 Annexure: Example procurement clause (short).....	28





A.6 Annexure: Pilot Procurement Requirements.....	29
A.7 Annexure: sample ingest manifest (JSON).....	33

FIGURES

Figure 1: The problem and the outcome (conceptual).....	4
Figure 2: End-to-end audit trail.....	6
Figure 3: Layered reference architecture.....	7
Figure 4: Ingest-to-access pipeline.....	9
Figure 5: Model governance lifecycle.....	11
Figure 6: Sensitivity and PII handling decision flow.....	12
Figure 7: Governance roles and decision gates.....	13
Figure 8: Phased implementation roadmap.....	14
Figure 9: Human-in-the-loop review workflow.....	15
Figure 10: Regime-to-control mapping matrix.....	18
Figure 11: Provenance event model (PROV-O).....	19
Figure 12: Deployment topologies and data residency.....	21
Figure 13: Deployment topologies and data residency.....	30

TABLES

Table 1 : Mapping checklist.....	24
----------------------------------	----

Authorship and usage

This document is an industry-facing extraction and enhancement of the framework described in the PhD thesis of Johannes J. Pieterse. Use it as a procurement brief, pilot plan, or governance artefact. For publication-ready use, replace pilot numbers, organisational names and metrics with concrete pilot outputs and signed governance artefacts.





1. Executive summary

The problem and the outcome (conceptual)

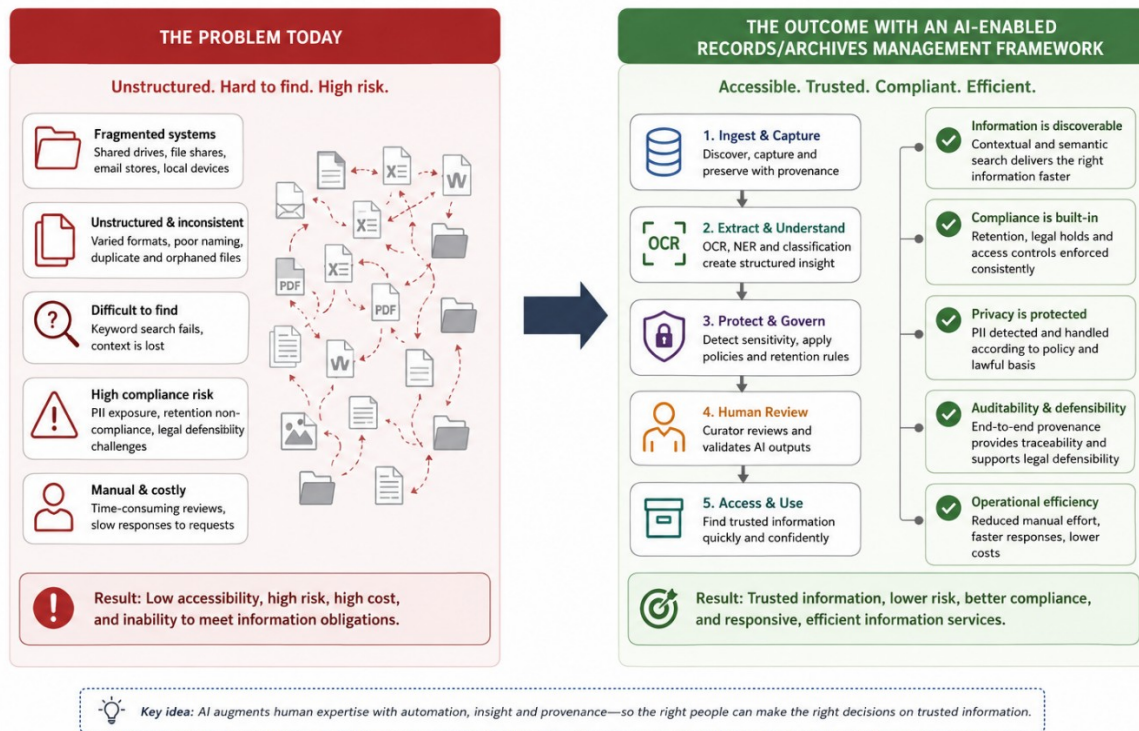


Figure 1: The problem and the outcome (conceptual)

This document extracts the framework presented in the thesis “Utilising Artificial Intelligence to Enhance Records Accessibility within a State-Owned Company in South Africa” and reframes it as a practical, industry-facing framework aimed at records professionals, IT leads and procurement teams. It is non-academic in tone, implementation oriented, and designed to be usable as:

- (a) an internal business-case and requirements brief;
- (b) an RFP / procurement annex; and
- (c) an operational implementation checklist for pilot and rollout.



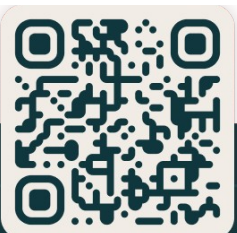


2. Purpose and scope

- **Purpose:** Provide a concise, actionable framework for introducing AI/ML capabilities into records management for large-scale unstructured estates (shared drives, network file shares, email stores), with an emphasis on governance, privacy and data-protection compliance, legal defensibility (access-to-information laws and national archival statutes), and operational adoption. This framework is written for an international audience and is vendor- and jurisdiction-agnostic.
- **Scope:** Practical discovery, OCR/NER provenance, classification, sensitivity detection, human-in-the-loop review, provenance capture, model governance, and phased implementation. Technology-agnostic; maps to common cloud and on-prem stacks.

3. Core principles

1. **Provenance-first:** Every AI-derived assertion must be accompanied by machine-readable provenance (what, who/what ran it, when, which model/version, configuration and confidence).
2. **Privacy-by-design:** Detect and protect PII early; record lawful-basis decisions; restrict output accordingly.
3. **Human-in-the-loop:** High-risk actions (disposal, transfer, sensitive access) require human validation. AI is an assistant, not an arbiter.
4. **Standards-aligned:** Map to applicable national data-protection and access-to-information laws (for example GDPR or FOIA-style statutes), national archival legislation, and ISO standards such as ISO 15489 / 23081 / 16175 / 30301 / ISO/IEC 23894 / 42001 to make outputs auditable across jurisdictions.





End-to-end audit trail (what is recorded, where and why)

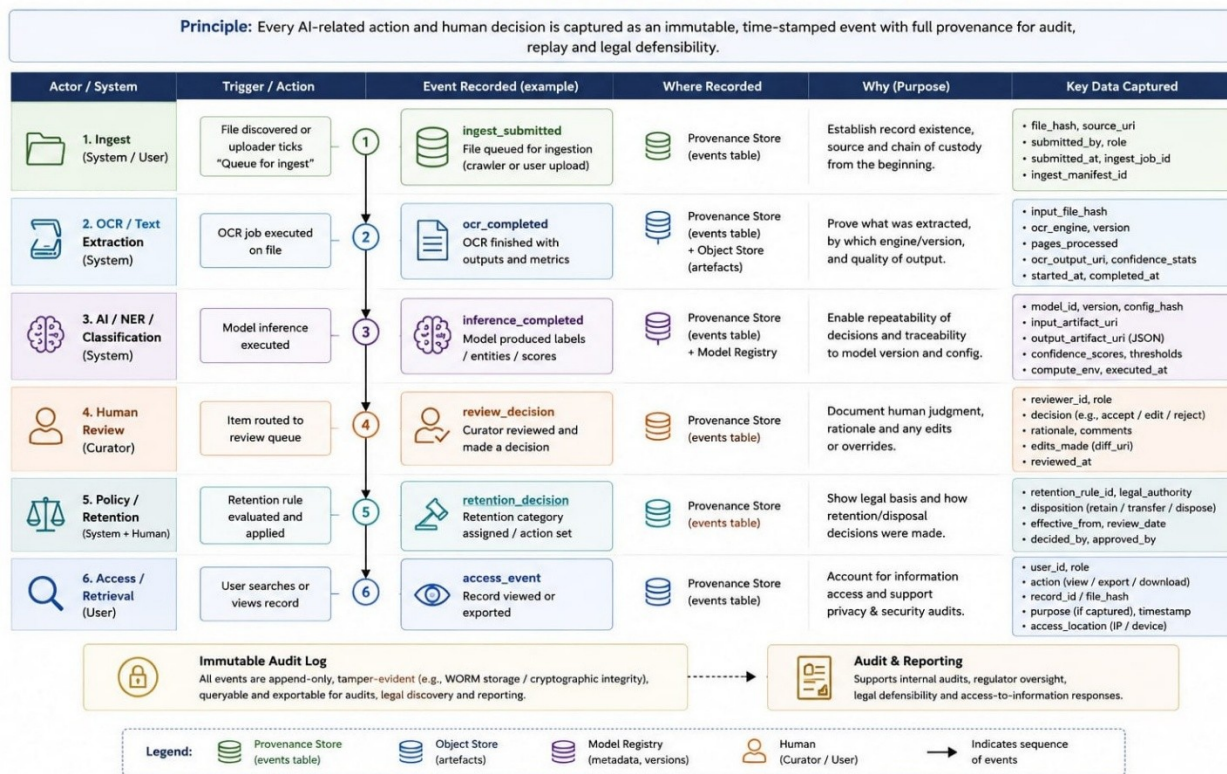


Figure 2: End-to-end audit trail

5. **Phased and measurable adoption:** Start with pilots, canary deployments and measurable KPIs (precision/recall, time-to-discovery, access-to-information response SLA compliance).





4. Architecture (industry view)

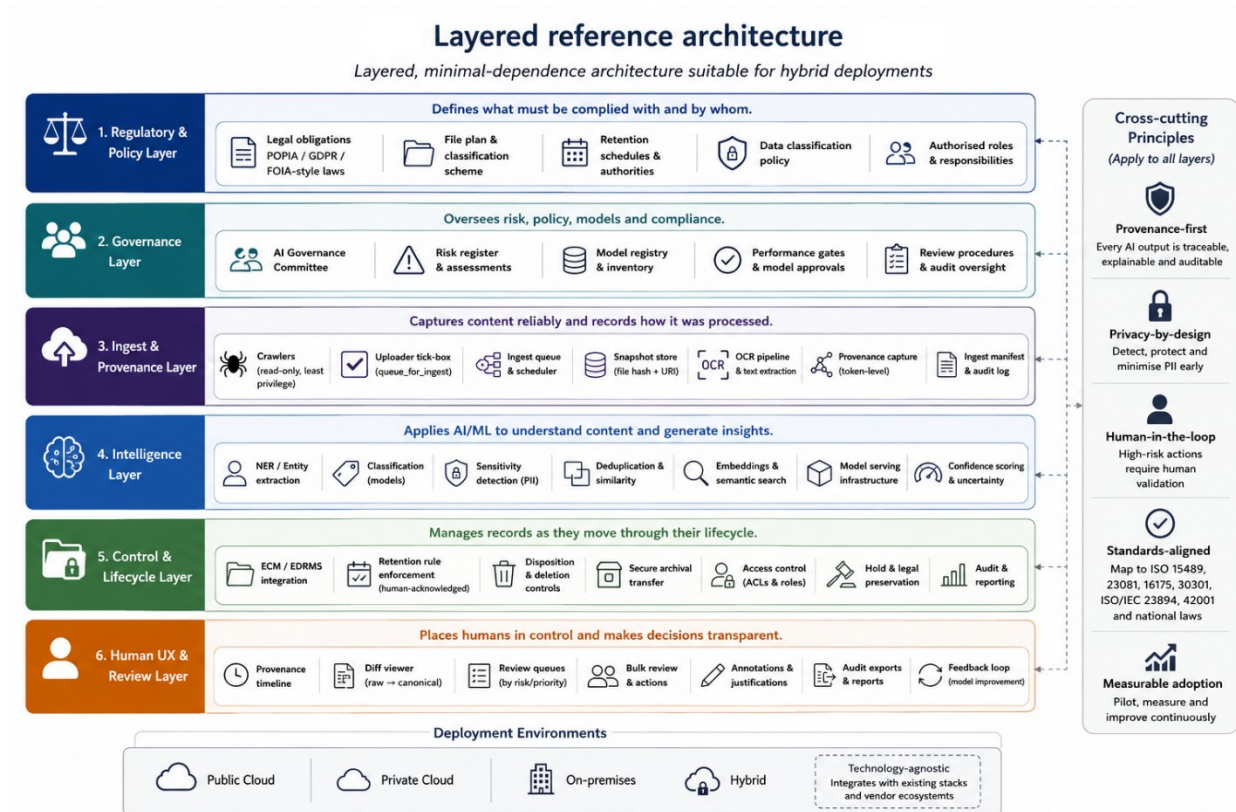


Figure 3: Layered reference architecture

Layered, minimal-dependence architecture suitable for hybrid deployments:

- **Regulatory & policy layer:** Legal obligations, file-plan, retention authorities, data-classification policy, authorised roles. This layer is the source of truth for what the law and the institution require: it defines the obligations, the file-plan and retention rules, and who is permitted to do what, and every layer above must honour those constraints.
- **Governance layer:** AI Governance Committee, risk register, review procedures, model registry and performance gates. This layer is where people hold the AI to account: the committee approves models for production, the risk register tracks what could go wrong, and the model registry and performance gates keep an unproven model away from live records.
- **Ingest & provenance layer:** Crawlers, snapshot store (file hash + URI), OCR pipeline, token-level provenance capture, ingest manifest and tick-box for





uploader-triggered ingestion. This layer is the controlled front door: it brings content in without altering the originals and stamps each step with provenance, so everything that follows can be traced back to a verifiable source.

- **Intelligence layer:** NER/entity extraction, classification models, sensitivity detectors, deduplication engines, embeddings/semantic search indices and model-serving infrastructure. This layer does the work of understanding the content - recognising entities, classifying records, flagging sensitive material and powering search - and is deliberately swappable, so models can be upgraded without disturbing the layers around it.
- **Control & lifecycle layer:** ECM / EDRMS integration, retention rule enforcement (human-acknowledged), secure archival transfer, ACLs. This layer turns decisions into action inside the systems of record: it enforces retention rules (only ever with a human's acknowledgement), moves material into secure archival custody, and controls who can see what.
- **Human UX & review layer:** Provenance timeline, diff viewer, review queues, bulk review tooling and audit exports. This layer is where people actually work with the system: it makes the AI's reasoning visible, lets curators review and correct at scale, and produces the audit evidence that regulators and auditors ask for.





5. Key components and capabilities

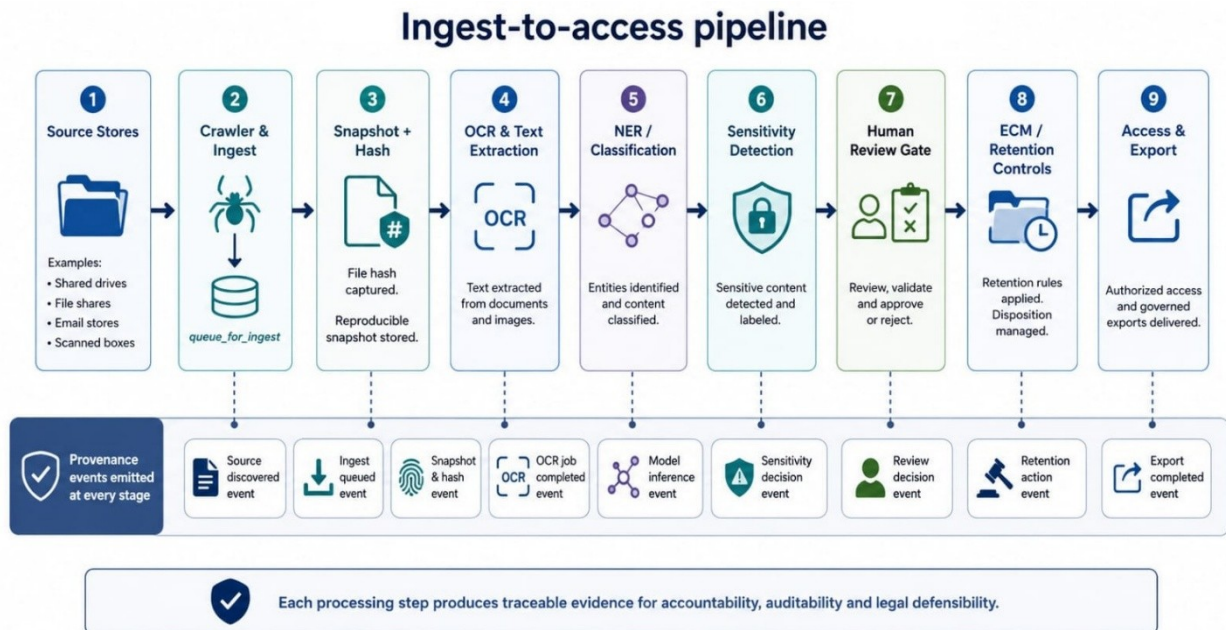


Figure 4: Ingest-to-access pipeline

1. Crawler & Ingest

- Read-only, least-privilege crawler with incremental scanning: it reads from the source stores without ever modifying them, runs under the narrowest access rights that still let it see the content, and on each pass picks up only what is new or changed, so repeated scans stay fast and never disturb the originals.
- An ingest queue fed by an uploader tick-box (queue_for_ingest): a person or an automated watcher flags an item for processing, and it joins an orderly, auditable queue rather than being processed silently, giving a single clear point of entry into the pipeline.
- Snapshot store recording each file's cryptographic hash alongside its object-store location (URI): the hash fixes exactly which bytes were processed, so any later result can be reproduced and verified, and the URI retrieves that exact version again.





2. OCR & Text Extraction

- Layout-aware optical character recognition (OCR) that understands page structure (columns, tables, headings) instead of reading text as one flat stream, and records where each extracted character sits (page and offset) so every word can be traced back to its exact place on the original page.
- Raw OCR output is kept as a first-class artefact in its own right and is never written back over the source: the original is preserved untouched while the machine-read text sits beside it as reviewable, re-runnable evidence.

3. NER / Classification

- Classifiers and named-entity recognition (NER) trained on the organisation's own material and tuned to its file plan and house terminology, so categories and entities reflect how this institution describes its records rather than a generic, off-the-shelf vocabulary.
- Configurable confidence thresholds decide each item's path automatically: a high-confidence result can flow straight through, while anything below the threshold or flagged high-risk is routed to a human, so effort is spent where the model is least sure.
- A model registry records, for every model in use, where its training data came from, which evaluation sets it was tested against, and how it scored, so any decision the AI influenced can be tied back to a specific, documented model version.





Model governance lifecycle (MLOps)

How the AI is kept accurate and accountable over time.

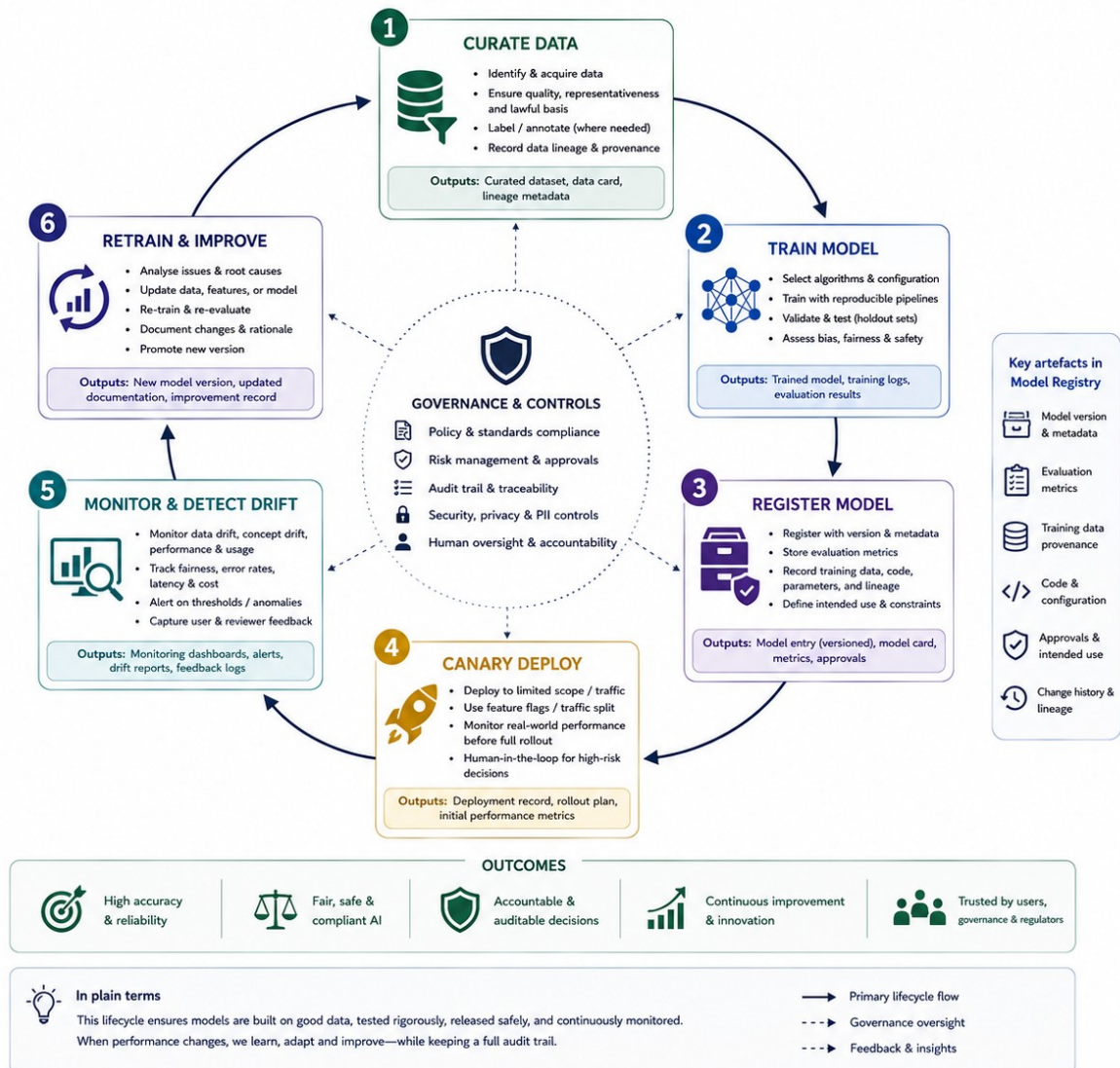


Figure 5: Model governance lifecycle

4. Sensitivity Detection & Privacy

- Detectors for personal and special-category data (names, identity numbers, health and financial markers) run early in the pipeline, so sensitive content is recognised before it is indexed or surfaced, not after.
- Policy then drives what happens to that sensitive content: it can be redacted, indexed only in a limited way, or withheld entirely, with the choice governed by configurable rules rather than left to each operator.



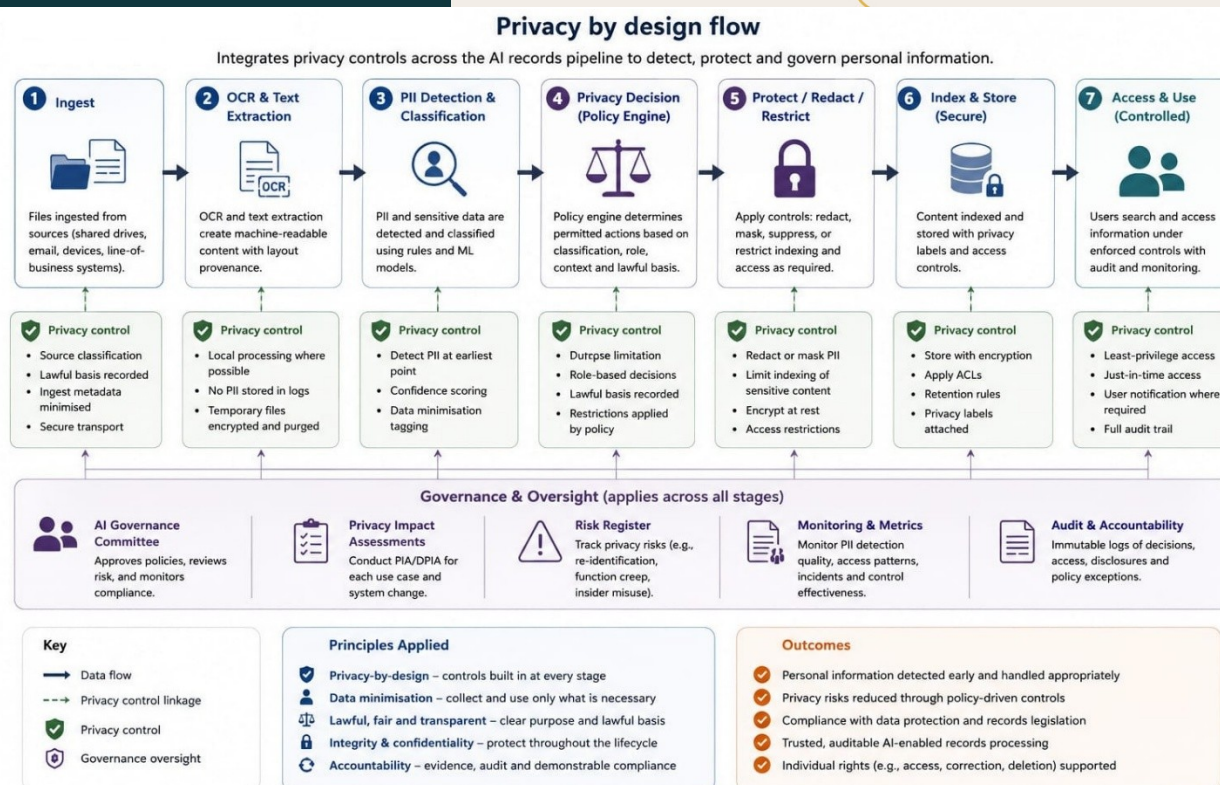


Figure 6: Sensitivity and PII handling decision flow

5. Provenance Store & Event Sourcing

- Provenance is captured as append-only events (processing jobs, review actions, policy decisions) that are never edited or deleted, stored as structured JSON so the full history of any record can be audited and replayed step by step.

6. Human Review & Workflows

- Items the model is unsure about, or that carry higher risk, are surfaced to a curator rather than actioned automatically, keeping a qualified human in control of the decisions that matter most.
- A diff viewer shows the raw machine output beside the cleaned, canonical text and any edits a reviewer made, so corrections stay transparent and the reasoning behind the final version is visible.





7. APIs & Integration

- POST /api/ingest (queue_for_ingest, metadata)
- GET /api/provenance/:record_id
- POST /api/review/:job_id/decision
- Integration adapters connect the pipeline to the systems records already live in (AtoM, SharePoint/Teams, M-Files, OpenText, and other existing ECM/EDRMS connectors), so it augments the current estate rather than replacing it.

6. Governance & roles

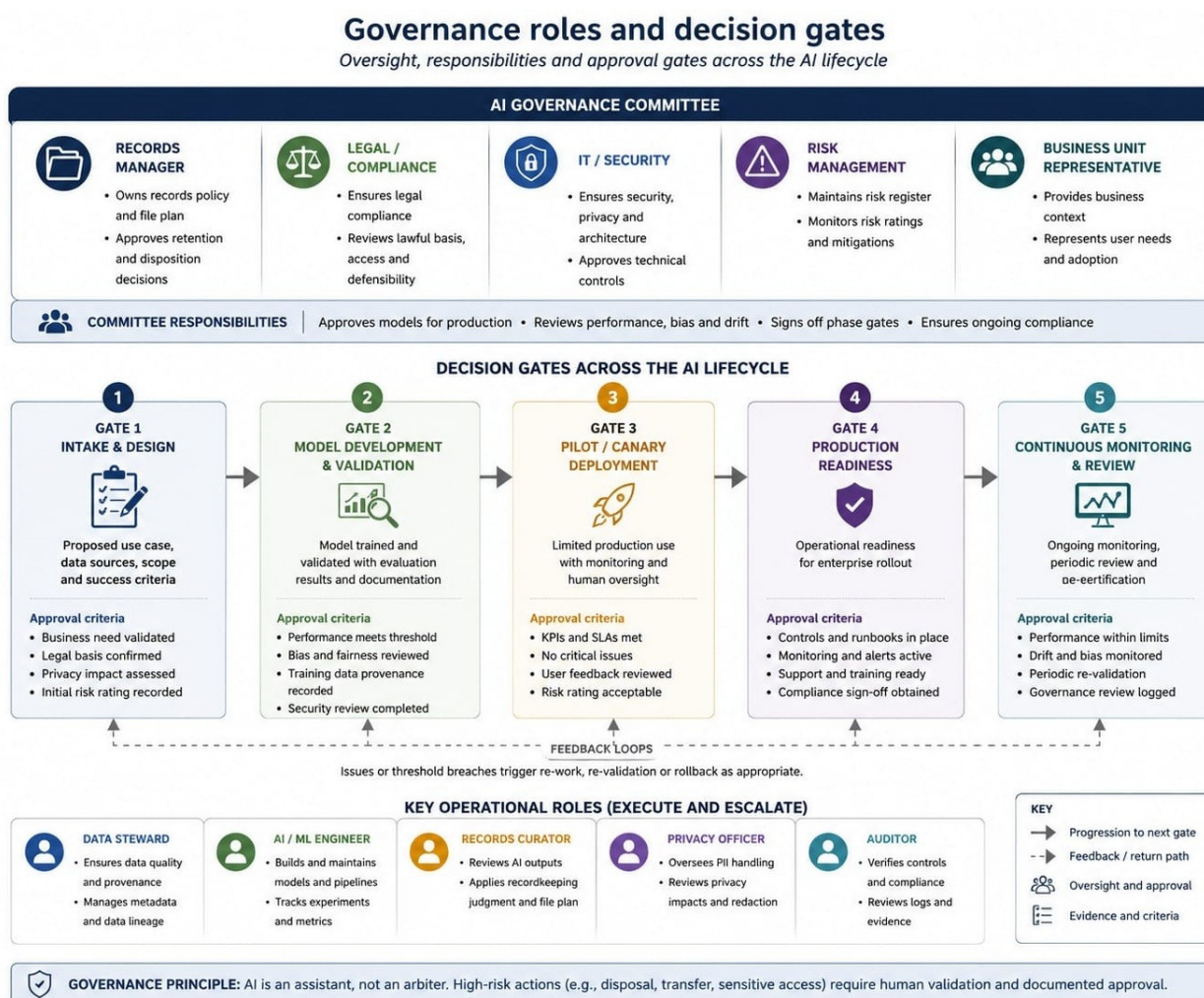


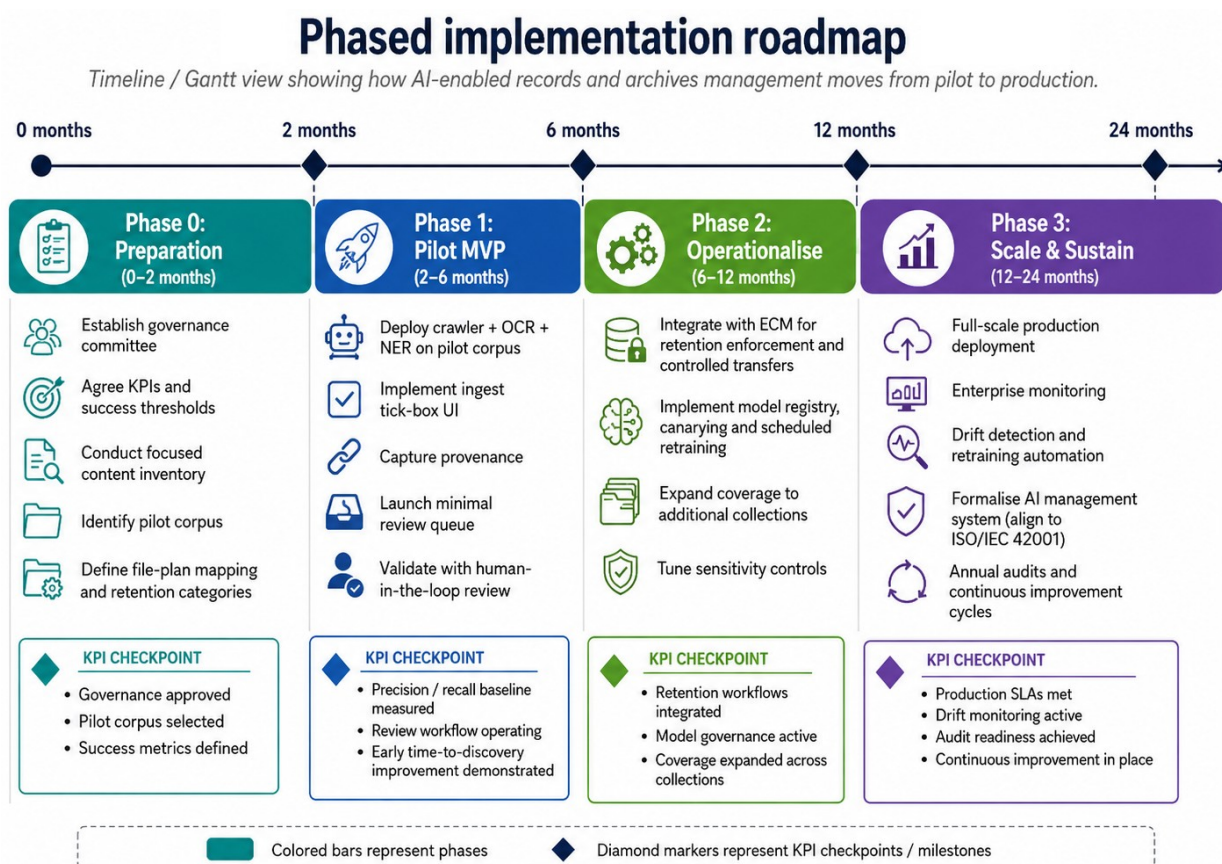
Figure 7 Governance roles and decision gates





- **AI Governance Committee:** Records Manager, Legal, IT/Security, Risk, and Business Unit representative. Approves models for production, reviews bias/drift and signs off phase gates.
- **Model Owner / Data Steward:** Responsible for dataset curation, maintaining labelled evaluation sets and monitoring performance.
- **Reviewers / Curators:** Records staff empowered to resolve review queues and to authoritatively approve retention and archival transfers.
- **Platform Ops / SRE:** Manages model serving, scaling, backups and incident response.

7. Implementation roadmap (MVP → Production)



Outcome: phased, measurable adoption from readiness to trusted enterprise operation.



Figure 8: Phased implementation roadmap

Phase 0: Preparation (0–2 months) - Establish governance committee; agree KPIs and success thresholds. - Conduct a focused content inventory and identify pilot corpus. - Define file plan mapping and retention categories.

Phase 1: Pilot MVP (2–6 months) - Deploy crawler + OCR + NER on pilot corpus. - Implement ingest tick-box UI, provenance capture and minimal review queue. - Validate with human-in-the-loop, collect precision/recall metrics.

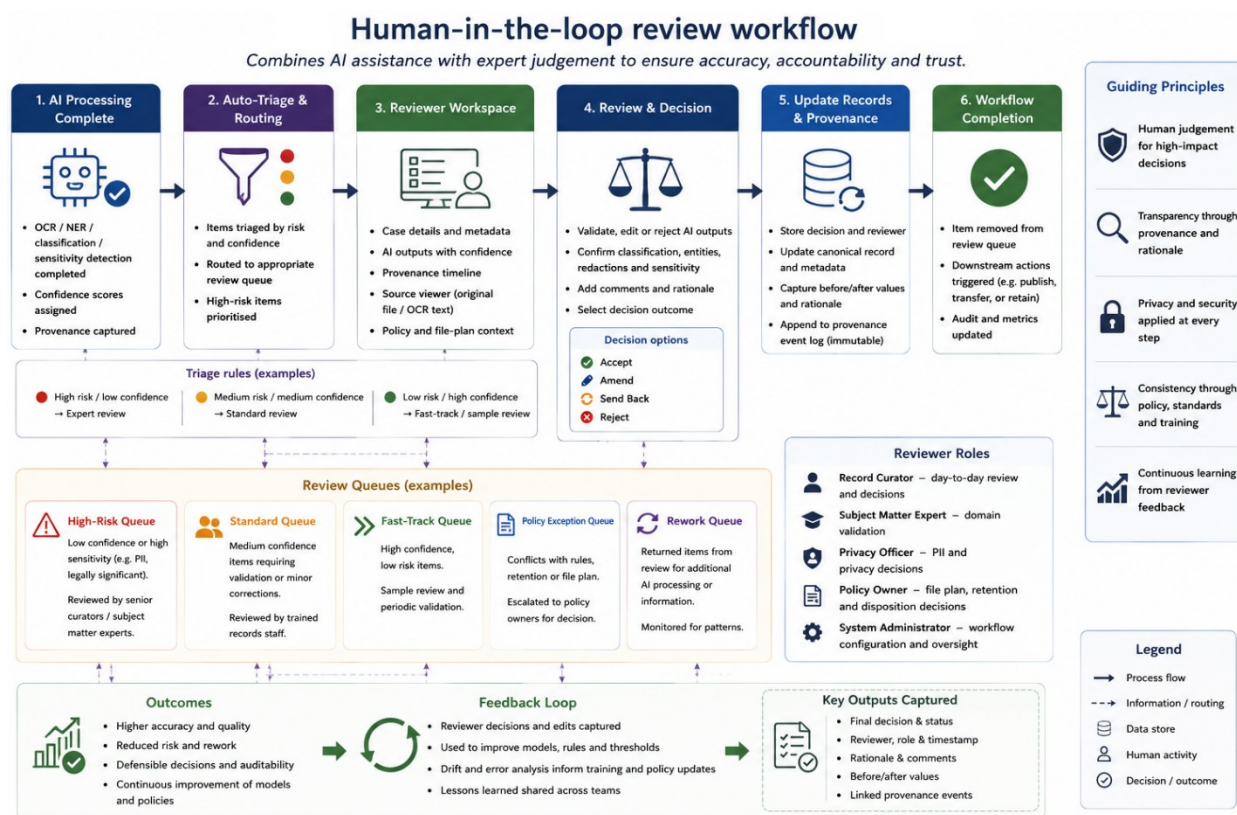


Figure 9: Human-in-the-loop review workflow

Phase 2: Operationalise (6–12 months) - Integrate with ECM for retention enforcement and controlled transfers. - Implement model registry, canarying and scheduled retraining. - Expand coverage to additional collections and tune sensitivity controls.

Phase 3: Scale & Sustain (12–24 months) - Full scale production, enterprise monitoring, drift detection and retraining automation. - Formalise AI management system (align to ISO/IEC 42001), annual audits, and continuous improvement cycles.





8. Minimum viable deployment checklist (for procurement/ops)

- Legal sign-off on pilot (data-protection and access-to-information mapping).
- Defined pilot dataset and success criteria (accuracy targets, reduction in manual hours, access-to-information SLA targets).
- Provenance JSON schema and database column (JSONB) agreed.
- APIs available for ingest, provenance and review.
- Human review dashboard with assign/claim/complete actions.
- Backup and immutable logs for auditability.

9. Metrics & KPIs (suggested)

- Classification precision and recall, reported per file-plan category: precision is how often a category is assigned correctly, recall is how much of each category is actually found, broken down so weak categories are visible rather than hidden in an average.
- Time-to-discovery, the median time to locate a record, compared before and after the pilot to show the real-world speed gain in plain terms.
- Access-to-information response SLA achievement rate: the share of requests answered within their statutory deadline, the headline measure of legal responsiveness.
- Review backlog size and reviewer throughput: how much is waiting for human review and how quickly reviewers clear it, so the human-in-the-loop step is resourced before it becomes a bottleneck.
- Model drift indicators (shifts over time in the data the model sees) and retraining frequency, so accuracy is actively monitored rather than assumed to hold.





10. Checklist for publishable industry artefact

- Non-academic tone with actionable sections (checklist, roadmap, APIs, KPIs).
- Implementation templates (provenance JSON example, API endpoints, DB schema suggestion).
- Mapping to standards and statutory instruments.
- Short case-study template to describe pilot outcomes.





Annextures

A.1 Annexure: Mapping to standards & statutes (short)

Regime-to-control mapping matrix

Maps regulatory regimes and statutory obligations to framework controls and recommended configurations.

Regulatory regimes (Examples)	Framework controls (ID) and recommended configuration (summary)															Notes / Jurisdictional considerations	
	Privacy & Data Protection				Access & Transparency			Security & Integrity			Records & Information Governance			AI Governance			
Statutes / obligations	C-PRV-01 Lawful basis & purpose limitation	C-PRV-02 PII detection & data minimisation	C-PRV-03 Consent & individual rights	C-PRV-04 Retention & disposal controls	C-ACC-05 Access request handling	C-ACC-06 Exemptions & redactions management	C-ACC-07 Proactive disclosure & transparency	C-SEC-03 Access control & least privilege	C-SEC-04 Encryption (At rest & in transit)	C-SEC-05 Audit logging & immutable records	C-RMG-08 Classification & sensitivity labelling	C-RMG-09 Retention scheduling & authority	C-RMG-10 Provenance & chain of custody	C-AI-11 Model governance & registry	C-AI-12 Human review for high-risk outcomes	C-AI-13 Bias, fairness & performance monitoring	
General Data Protection (e.g., GDPR – EU) Art. 5, 6, 12–22, 25, 32	✓ Required Document lawful basis per use	✓ Enable PII scanning; minimise by design	✓ Manage rights (DSAR) & consent records	✓ Enforce retention schedules; automate	✓ SLA + workflow; track & log	✓ Define exemptions; apply test & redact	✓ Publish policies & data inventory	✓ RBAC + least privileges; MFA	✓ AES-256 at rest; TLS 1.2+ in transit	✓ Immutable logs; 1 year+ retention	✓ Apply sensitivity labels	✓ Retention by authority; auto review	✓ Provenance for all AI outputs	✓ Register models; document lineage	✓ Human review for high-risk outputs	✓ Evaluate & monitor for drift/bias	DPIA for high-risk processing; cross-border transfer rules apply
General Data Protection (e.g., POPIA – South Africa) Sec. 4–11, 13–22	✓ Process limitation; responsible party	✓ Limit collection; PII detection mandatory	✓ Handle PAIA requests for POPIA records	✓ Retention per lawful purpose; dispose securely	✓ PAIA request workflow; respond in time	✓ Apply justifiable limitations; partial access	✓ Information manual & public guide	✓ Role-based access; segregation	✓ Encrypt sensitive PII	✓ Audit logs; incident records	✓ Classify PII & special personal info	✓ Retain per records schedule	✓ Record processing activities	✓ Model inventory & document purpose	✓ Curator review for sensitive records	✓ Monitor accuracy & fairness	Information Officer accountability required
Access to Information (e.g., FOIA – US) 5 U.S.C. § 552	– Not primarily applicable	– Not primarily applicable	– Not primarily applicable	– Not primarily applicable	✓ FOIA intake, tracking & response	✓ Apply 9 exemptions; redact PII	✓ Reading room & proactive releases	✓ Limit access to responsive records	✓ Encrypt in transit & at rest	✓ Log search & disclosure activities	✓ Label exempt & sensitive	✓ Retain per NARA schedules	✓ Maintain chain of custody	✓ Recommended for complex systems	✓ Review redactions & releases	✓ Monitor search & model quality	FOIA exemption supersede release unless waived
Access to Information (e.g., PAIA – South Africa) Act 2 of 2000	– Not primarily applicable	– Not primarily applicable	– Not primarily applicable	– Not primarily applicable	✓ PAIA request workflow; track & log	✓ Controls sections 46 limitations; redact	✓ Guide on how to access information	✓ Restrict access to records	✓ Encrypt sensitive records	✓ Audit & notify breaches	✓ Classify records by sensitivity	✓ Retain per approval schedules	✓ Document handling & disclosure	✓ Recommended for automated decisions	✓ Human oversight of disclosures	✓ Monitor accuracy & false positives	Section 51 manual & records inventory required
Health Data Protection (e.g., HIPAA – US) 45 CFR Parts 160 & 164	✓ Lawful basis: Treatment, Payment, Operations	✓ Detect ePHI; minimum necessary only	✓ Patient rights access & amendment	✓ Retain per policy; secure disposal	– Not typically applicable	✓ Apply minimum necessary standard	– Not typically applicable	✓ Role-based access; authentication	✓ Encrypt ePHI	✓ Audit access; limit retain 6+ years	✓ Mark ePHI; incidental use	✓ Retain per policy & legal holds	✓ Track ePHI use & disclosure	✓ Validate models for ePHI use	✓ Review AI outputs involving ePHI	✓ Monitor model performance	BAA required for third-party processors
Financial Data Protection (e.g., GLBA – US) 15 U.S.C. § 6801–6809	✓ Notice & privacy principles	✓ Limit sharing; detect sensitive financial data	✓ Consumer rights (access & correction)	✓ Retain per policy; dispose securely	– Not typically applicable	– Not typically applicable	– Not typically applicable	✓ Access controls; need-to-know	✓ Encrypt financial data	✓ Audit & monitor access	✓ Label financially sensitive data	✓ Retain per regulation & policy	✓ Maintain transaction records	✓ Govern models using financial data	✓ Human review for adverse actions	✓ Monitor bias & accuracy	Safeguards Rule compliance required
Records/Archives statutes (e.g., National Archives Acts) Various national laws	– Not primarily applicable	– Not primarily applicable	– Not primarily applicable	✓ Retain per approved records schedules	✓ Enable lawful access to records	✓ Protect restricted records	✓ Support public information mandate	✓ Preserve records integrity	✓ Preservation storage security	✓ Audit preservation actions	✓ Apply record classification scheme	✓ Follow retention authorities	✓ Provenance for archival transfer	✓ Document AI processing for archival value	✓ Archivist review & approval	✓ Monitor information quality	Ensure admissibility & evidential value
Legend					Notes					Abbreviations							
✓ Applicable – implement control (as configured) ✨ Recommended – implement if relevant to context / risk – Not primarily applicable in this regime					• Controls (C-xxx) are defined in the framework control catalogue. • Recommended configurations are baseline; tailor to organisational risk, sector rules and contracts. • Where national law is more specific, it takes precedence over this mapping.					PII – Personally Identifiable Information ePHI – Electronic Protected Health Information DSAR – Data Subject Access Request RBAC – Role-Based Access Control CMK – Customer-Managed Key BAA – Business Associate Agreement							

Figure 10: Regime-to-control mapping matrix

- Data-protection and access-to-information laws: Map the provenance and processing logs to meet the obligations of applicable data-protection regimes (e.g. GDPR) and freedom-of-information/access-to-information statutes in the operating jurisdiction.
- National archival legislation: Ensure file-plan, appraisal and disposal mapping aligns to the country-specific archival statute or national records disposal authority.
- ISO 15489 / 23081 / 16175 / 30301 / ISO/IEC 23894 & 42001: Metadata, records management system alignment and AI risk/management system practices.





A.2 Annexure: AI RAM Framework – API / JSON-LD / provenance / PROV-O

Contents

1. API contracts and example endpoints
2. JSON-LD / provenance / PROV-O examples
3. Provenance & evidence model

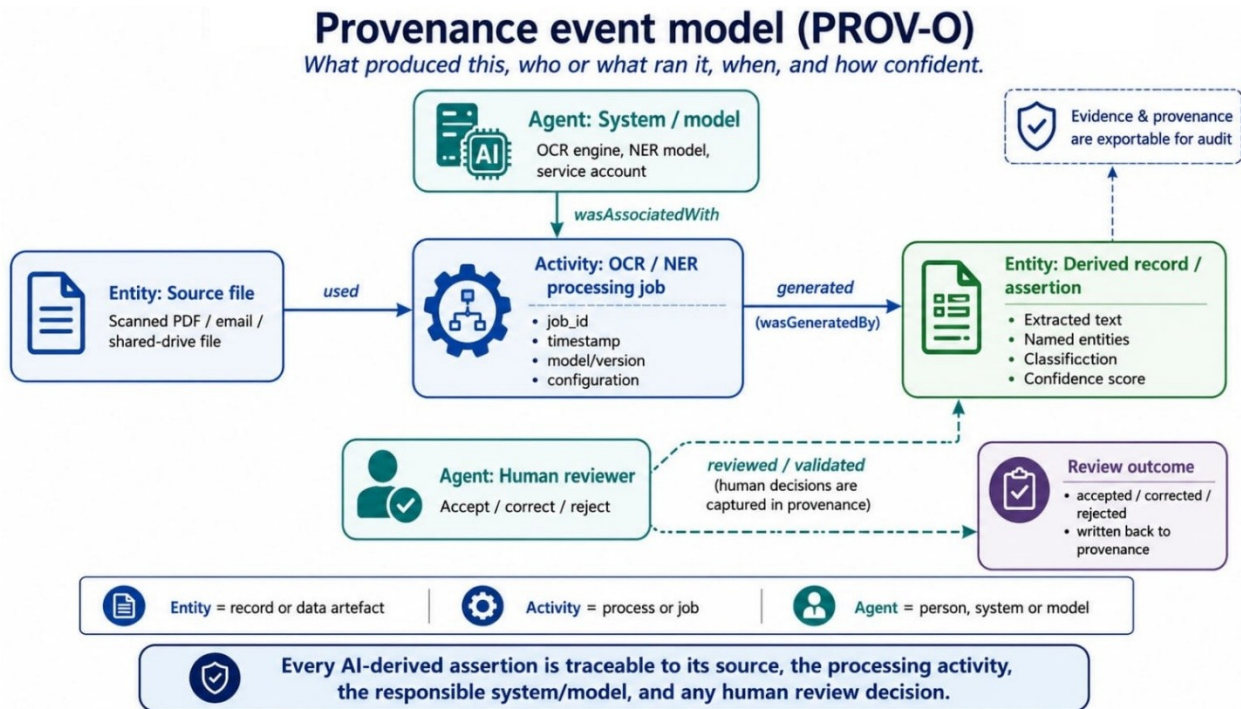
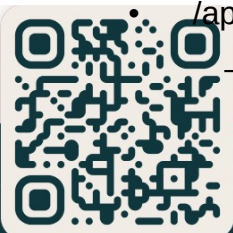


Figure 11: Provenance event model (PROV-O)

4. Deployment patterns: on-prem, cloud (multi-region), hybrid
5. Sample export/import formats and packaging (METS, JSON, bagit)
6. Operational notes: keys, certificates, logging
7. API contracts and example endpoints (OpenAPI-style descriptions)
 - /api/v1/ingest
 - POST
 - Body: multipart/form-data or application/json
 - Fields: file, metadata (JSON), provenance (JSON)
 - Response: 202 Accepted, job_id
 - /api/v1/ingest/{job_id}/status
 - GET





- Response: status, progress, errors
- /api/v1/records/{id}
 - GET: returns metadata and access URLs (signed if necessary)
 - PATCH: update metadata (RBAC-protected)
 - DELETE: request deletion (subject to retention policy and legal hold)
- /api/v1/search
 - POST: query DSL (filters by metadata, fulltext, date ranges, confidence)
 - Response: results with provenance snippets
- /api/v1/provenance/{id}
 - GET: returns PROV-O/JSON-LD provenance graph for record
- /api/v1/audit/logs
 - GET: returns tamper-evident logs (signed entries)
- /api/v1/access-requests
 - POST: create a subject access / FOI request
 - GET: status and exported package

Authentication

- OAuth2 / OpenID Connect recommended for users and services
- Client credentials for service-to-service with scoped tokens
- Short-lived signed URLs for downloads; verify with HMAC or JWT

JSON-LD / provenance / PROV-O examples

- Give a JSON-LD snippet that models an ingest event, the agent (system), and the derived artifact. Use W3C PROV terms.

Provenance & evidence model

- Store provenance at event granularity: ingest, transform, classification, redaction, export
- Each event: timestamp (ISO8601 UTC), agent_id, action_type, inputs, outputs, signature (optional), job_id
- Tamper-evidence: sign logs with server key; support export with chain-of-custody manifest

Deployment patterns





Implementation roadmap

Figure 7 – Phased implementation roadmap: how long and in what order.

Timeframe	0 – 2 months	2 – 6 months	6 – 12 months	12 – 24 months
	Phase 0 – Foundation & Readiness	Phase 1 – Pilot & Validate	Phase 2 – Scale & Integrate	Phase 3 – Optimize & Innovate
Focus	Set up governance, policies, architecture and data foundation.	Pilot targeted use cases, validate value, improve models and processes.	Expand to more repositories and use cases; integrate and industrialize.	Optimize operations, drive continuous improvement and innovation.
Key deliverables	• Governance committee & policies • File plan & retention alignment • Architecture, security & access design • Data inventory & prioritization • Pilot backlog & success metrics	• Pilot environment & data pipelines • OCR, NER & classification pilots • Human review workflows • Provenance & audit logging • Pilot report & business case	• Production platform & integrations • Expanded model library & registry • Retention & disposal automation • Access request workflows • Change management & training	• Advanced analytics & GenAI use cases • Continuous model monitoring • Cost & performance optimization • Innovation backlog & roadmap • Value realization report
KPI checkpoints (Examples)	• Data sources assessed: 100% • Governance artifacts approved • Security controls implemented • Baseline capture complete	• Pilot precision ≥ 85% • Time-to-discovery ↓ 30% • Review accuracy ≥ 90% • User satisfaction ≥ 75%	• Repositories onboarded: ≥ 60% • Automation rate ≥ 60% • Access request SLA met ≥ 90% • Cost per record ↓ 25%	• Automation rate ≥ 80% • Time-to-discovery ↓ 50% • Model drift within threshold • ROI delivered & tracked

Deployment patterns

Deployment topologies and data residency: where the data physically lives and who holds the keys.

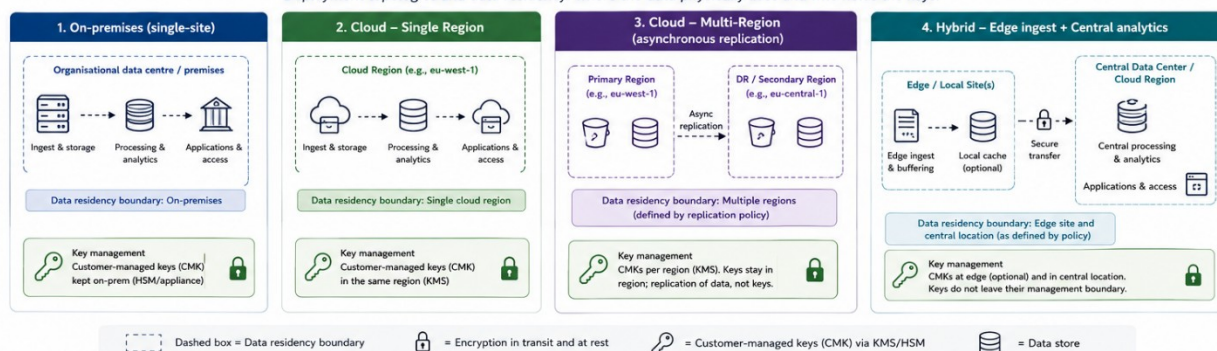


Figure 12: Deployment topologies and data residency

- On-prem: single-region, control over data residency; use local object store (S3-compatible or POSIX), single point of authority for KMS
- Cloud single-region: managed services; ensure regional placement matches legal requirements, use provider KMS with CMK where possible
- Cloud multi-region replication: asynchronous replication; ensure legal mapping for transfers; use encrypted replication channels
- Hybrid: edge ingest + centralised analytics; keep primary content in on-prem vault, mirror derived indexes to cloud for processing

Packaging and exchange

- METS packaging for complex archival packages; JSON export for lightweight exchange; bagit for physically moving collections

Operational notes

- Rotate keys and credentials; maintain vault for secrets
- Strong TLS, HSTS, and CSP for web interfaces





- Logging: structured logs, retain as per control, exportable for audits

Example Provenance JSON (schema fragment)

```
{ "record_id": "", "source_file": "", "file_hash": "sha256:", "ingest_timestamp":  
  "2026-06-20T08:00:00Z", "ingested_by": "uploader-username", "processing_jobs":  
  [ { "job_id": "ocr-uuid", "job_type": "ocr", "processor": "tesseract-4.1",  
    "processor_version": "4.1.1", "timestamp": "2026-06-20T08:10:00Z", "inputs": [""],  
    "outputs": [""], "notes": "layout-aware OCR run" }, { "job_id": "ner-uuid", "job_type":  
    "ner", "model_name": "ner-archive-v1", "model_version": "2026-05-12",  
    "timestamp": "2026-06-20T09:00:00Z", "confidence_threshold": 0.6, "outputs": [""],  
    "human_review_required": true } ], "ai": { "model_registry_id": "ner-archive-v1",  
    "model_version": "2026-05-12", "inference_config": { "prompt": "...", "temperature":  
    0.0 }, "inference_hash": "sha256:...", "explainability": { "saliency_uri": "..." } },  
  "human_review": { "status": "pending|accepted|rejected|corrected", "reviewer_id":  
    null, "review_timestamp": null, "corrections_uri": null } }
```





A.3 Annexure: AI RAM Framework - Jurisdiction-agnostic Template and Checklist

Purpose

This annex provides a jurisdiction-agnostic template and checklist to map local legal and regulatory obligations to the controls and modules described in the Heratio Industry AI for RM/Archives framework. It is intended for implementers and procurement teams to quickly identify where configuration or local policy must be applied.

How to use

1. Identify the target jurisdiction(s).
2. For each law/regime, record the specific obligations that affect processing, retention, access, data residency, and disclosure.
3. Map each obligation to a framework control (control_id) from the main framework and add recommended configuration values.
4. Use the checklist during procurement, deployment and audits.

Representative regimes covered (templates)

- **GDPR (European Union):** personal data processing, lawful basis, DPIAs, data subject rights, data protection impact assessment, cross-border transfer restrictions, fines and supervisory authority obligations.
- **FOIA / Freedom of Information (e.g. US state/federal FOIA, UK FOI):** public access obligations, exemptions, response timelines and publication requirements.
- **HIPAA (USA, health data):** special categories (PHI), minimum necessary, BAAs, breach notification timelines.
- **POPIA (South Africa):** data protection principles, retention, special personal information, data subject rights.
- **Example other regimes:** APPI (Japan), PIPEDA (Canada), LGPD (Brazil), etc. Use the template rows in the CSV to add local laws.

Template: Law summary (editable)





Name: [e.g. GDPR]

Jurisdiction: [EU / Member State]

Scope: [what data/persons/organisations are covered]

Key obligations (short):

- Lawful basis for processing
- Data subject rights required
- Retention constraints
- Data breach notification timeline
- Cross-border transfer rules
- Special categories handling

Mapping checklist (recommended)

For each obligation above, add a mapping to the framework control. Example columns are provided in the table.

Table 1 : Mapping checklist

law_name	jurisdiction	scope	key_obligations	control_id	recommended_config
GDPR	EU	Personal data of EU residents	Lawful basis; DS rights; DPIA; Transfer rules	C-PRV-01	Configure lawful_basis; record ROPA; enable purpose labels
FOIA	various	Public bodies' records	Publication; exemptions; timelines	C-ACC-05	Redaction queue; SLA timers; audit export
HIPAA	USA	PHI / Health data	BAA; Minimum necessary; breach notification	C-SEC-03	PHI tagging; BAAs; breach timers
POPIA	South Africa	Personal data	Processing conditions;	C-PRV-01	Map RoPA; retention controls; DPO





			rights; accountability		
--	--	--	---------------------------	--	--

Sample mapping entries (illustrative)

- **control_id:** C-PRV-01 **control_name:** Lawful Basis & Purpose Limitation
obligation: GDPR; lawful basis required for processing personal data; consent or legitimate interest; purpose limitation recommended_config: Require configured lawful_basis per dataset; record ROPA entry; enable purpose labels on ingest
- **control_id:** C-RES-02 **control_name:** Data Residency Constraint
obligation: GDPR; restrict transfers outside EU without adequate safeguards
recommended_config: Multi-region deployment flag; enable encryption-in-transit/at-rest and configure cross-region replication policy
- **control_id:** C-ACC-05 **control_name:** FOI / Access Request Handling
obligation: FOI; respond within statutory timeline; publish non-exempt records
recommended_config: Request workflow, redaction queue, SLA timers, audit trail and export for publication





A.4 Annexure: Regime-specific templates

GDPR (EU): Template notes

- Data protection officer (DPO) required? [Yes/No]
- Record of processing activities (RoPA) required: map datasets to RoPA entries
- Data subject rights: access, rectification, erasure, restriction, data portability, objection; implement workflows and SLA tracking
- Data transfers: identify cross-border flows and apply Standard Contractual Clauses (SCCs) or other safeguards
- DPIA: require DPIA for large-scale processing or special categories
- Fines / sanctions: include legal hold and retention overrides for litigation

FOIA-style (Public Access): Template notes

- Public bodies must publish or provide access unless an exemption applies
- Exemptions and redaction: configure redaction workflows and reviewer roles
- Timelines: configure intake-and-response SLA timers and audit-proof evidence of response

HIPAA (US health): Template notes

- PHI tagging required; minimum-necessary principle applied to queries and exports
- Business Associate Agreement (BAA) required with vendors processing PHI
- Breach notification windows: no later than 60 calendar days for individual notice (large breaches also notify the regulator and media within 60 days; smaller breaches are reported to the regulator annually)

POPIA (South Africa): Template notes

- Conditions for lawful processing; data subject rights like GDPR but local distinctions
- Accountability and retention: register processing activities where required





Checklist (quick)

- Has each dataset been mapped to at least one legal regime and control in the spreadsheet?
- Are data residency and cross-border transfer constraints recorded and enforced?
- Is there a redaction/release workflow for FOI requests with auditor role?
- Are DPIAs/Risk Assessments required and linked to ingestion pipelines?
- Are breach-notification timers and contact roles configured?
- Are vendor contractual requirements (BAA, data processing addendum) recorded in procurement docs?





A.5 Annexure: Example procurement clause (short)

Vendor shall: maintain documented compliance with applicable data protection laws for the jurisdictions where the service is used; provide exportable evidence of processing activities, signed confidentiality and data processing agreements, and support data deletion/erasure on customer request within contracted timelines.





A.6 Annexure: Pilot Procurement Requirements

Purpose

This annex operationalises the AI RAM Industry Framework into procurement requirements, vendor acceptance tests and a vendor checklist for a pilot deployment. Use as an appendix to a standard RFP or as a standalone procurement brief for pilot vendors.

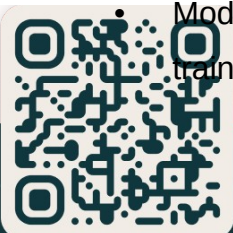
Pilot scope

- Pilot corpus: [to be filled by procuring organisation]; recommend a 10k–50k document subset representative of the estate (mixed formats, structured/unstructured, scanned PDFs, email exports).
- Pilot duration: 3 months (12 weeks) active testing + 4 weeks evaluation/reporting.
- Key outcomes: measurable improvement in time-to-discovery (target: 30–60% reduction), classification precision ≥ 0.85 for target categories, access-to-information (freedom-of-information) response SLA improvement to ≤ 10 days.

Mandatory functional requirements

- Read-only connector to source stores (SMB/NFS/SharePoint/IMAP) with incremental scanning and audit logging.
- Ingest API: POST /api/ingest accepting metadata and queue_for_ingest flag; support bulk manifest uploads.
- Provenance capture for every processing step (JSON schema provided in the framework appendix). Must record: processor name/version, timestamps, inputs/outputs, confidence scores and reviewer events.
- OCR pipeline with layout-aware extraction and page/offset provenance.
- Entity extraction (NER) and classification modules with configurable confidence thresholds and a review queue for low confidence/high-risk items.
- Sensitivity/PII detection with policy-driven redaction or limited indexing options.
- Human-in-the-loop review dashboard with assign/claim/complete workflow, diff viewer, and bulk-approved actions.

Model registry or metadata store recording model_name, model_version, training_date, evaluation_metrics, and training_data_origin.





Model governance lifecycle (MLOps)

How the AI is kept accurate and accountable over time.

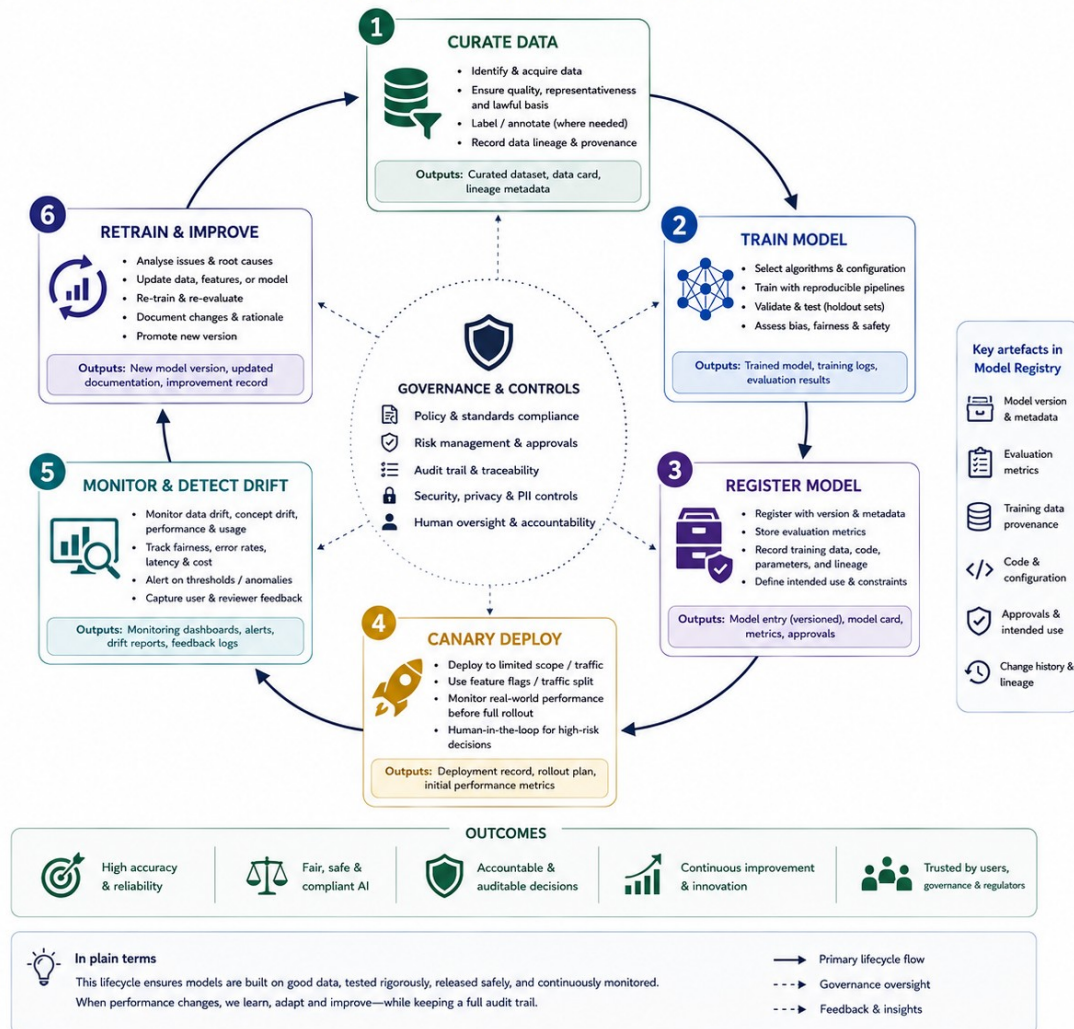
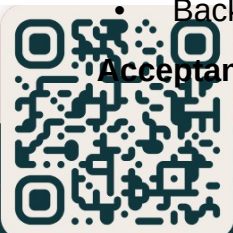


Figure 13: Deployment topologies and data residency

Non-functional requirements

- Deployment: support for on-prem and hybrid (no outbound storage of raw documents without signed agreement).
- Security: TLS for all endpoints, RBAC for reviewers, encrypted at rest, audit log immutability (append-only storage recommended).
- Performance: processing throughput baseline for pilot corpus (e.g. OCR + NER ≤ 1 minute/document average on pilot infra spec; provide sizing guidance).
- Backups and retention of provenance records for statutory retention windows.

Acceptance tests (must be demonstrated during pilot)





- Ingest manifest: upload a manifest of 1000 files with `queue_for_ingest` set; confirm all files are queued and provenance entries created.
- OCR fidelity: run OCR on 50 scanned documents; measure character accuracy and show provenance linking OCR outputs to source pages.
- Classification accuracy: vendor submits evaluation CSV; measured precision/recall meets thresholds for target categories.
- Review workflow: create 200 review jobs (low confidence); reviewers must be able to resolve 95% within the UI with exportable audit reports.
- Access-to-information scenario test: locate 20 named-record requests within SLA and provide export of the provenance chain for each located record.

Vendor checklist

- Provide a technical design that maps to the framework's layered architecture.
- Demonstrate model governance and retraining plan.
- Provide a deployment and rollback plan and a maintenance SLA.
- Provide evidence of data-protection and access-to-information compliance controls for the target jurisdiction(s).
- Provide references to prior deployments of similar scale (if any).

Procurement scoring matrix (example)

- Functional fit (40%); how well the solution meets mandatory functional requirements.
- Security & compliance (20%).
- Performance & scalability (15%).
- Implementation plan & support (15%).
- Cost & TCO (10%).

Deliverables during pilot

- Weekly processing reports (ingest counts, review backlog, model metrics).
- Final evaluation report including measured KPIs, lessons learned and recommended production steps.





A.7 Annexure: sample ingest manifest (JSON)

```
[ { "source_path": "\\fileshare\\projects\\docs\\doc1.pdf", "uploader":  
"user@example.org", "queue_for_ingest": true, "metadata": {"project": "finance",  
"retention": "7 years"} } ]
```

AI Management System Controls (ISO/IEC 42001

Clauses 4-10)

The sections above cover the AI-specific controls (ISO/IEC 42001 Annex A). The sections below complete the framework against the management-system requirements of ISO/IEC 42001 Clauses 4-10, so the framework maps essentially one-to-one onto the standard. All highlighted text is the new ISO/IEC 42001 material.

AI Risk and Impact Management

Closes ISO 42001 Clause 6.1 / 8.2-8.4 and Annex A.5; aligns ISO/IEC 23894 and ISO/IEC 42005.

The legal-mapping annexure tells you which laws apply. This section tells you how risk and impact are formally assessed, treated and recorded before any model touches live records, and on every significant change.

AI risk management process

A repeatable cycle, owned by the Model Owner and reviewed by the Governance Committee, mirroring ISO 31000 / 23894:

- **1. Identify** - for each AI use (classification, sensitivity detection, NER, disposal/transfer recommendation, semantic search), list what could go wrong:





misclassification, sensitivity miss, wrongful disposal, biased treatment of a group, provenance loss, erroneous assertion acted upon.

- **2. Analyse** - rate each risk on likelihood and consequence using a published scale, where consequence explicitly includes harm to data subjects, harm to affected groups, legal/statutory breach, and loss of evidential value of the record.

- **3. Evaluate** - compare against documented risk-acceptance criteria. Anything above the threshold cannot go to production without treatment and sign-off.

- **4. Treat** - choose avoid / reduce (e.g. raise the confidence threshold, add a deterministic detector, force human review) / transfer (contractual) / accept (with recorded justification and an accountable owner).

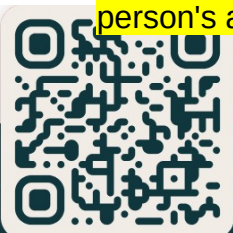
- **5. Monitor** - residual risks carry an owner, a review date, and a trigger (drift, incident, legal change) that reopens them.

A risk register records each risk: id, description, use/system, likelihood, consequence, owner, treatment, residual rating, review date.

AI system impact assessment (AISIA)

A documented assessment - broader than a privacy DPIA, which becomes one input to it - performed before deployment and on significant change (new model, new data source, new automated decision, expanded scope). It assesses impact across four dimensions specific to records and archives:

- **Individuals** - privacy, data-subject rights, fairness of any decision affecting a person's access or record.





- **Affected groups / society** - bias and exclusion (does sensitivity or classification systematically misfire for a language, community or record type), accessibility, and disproportionate suppression or exposure.

- **The institution** - legal/statutory exposure (access-to-information, archival statute), reputational and litigation risk.

- **The record itself** - authenticity, integrity and evidential value; risk of wrongful disposal or transfer; provenance completeness.

Triggers, outputs and sign-off: an AISIA is mandatory for any high-risk use (automated disposal/transfer, sensitivity-driven access decisions, processing of special-category data at scale). Its output is a recorded assessment with identified impacts, treatments and residual acceptance, signed off by the Governance Committee before go-live and retained as an audit artefact.

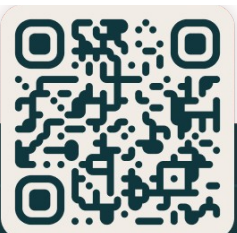
Internal Audit and Management Review

Closes ISO 42001 Clause 9.2 and 9.3.

Monitoring (KPIs, drift) tells you how the models perform. This section adds the independent check and the governance review that turn a set of controls into a managed system.

Internal audit programme

- A scheduled, risk-based audit programme (at least annually; high-risk uses more often) audits the AI controls against this framework, the AI policy, applicable law, and ISO 42001.





- **Auditor independence** - auditors do not audit their own work: a reviewer cannot audit the review queue they operate; a model owner cannot audit their own model governance.

- Each audit produces findings (conformity, nonconformity, observation), each finding routes into the corrective-action process below, and results are reported to the Governance Committee. Audit plans, findings and outcomes are retained.

Management review

The Governance Committee conducts a periodic management review (recommended quarterly, with a formal annual review) against a fixed agenda.

Inputs: status of actions from the previous review; changes in legal, regulatory or institutional context; AI performance metrics and drift; risk-register and AISIA outcomes; internal-audit results; incidents and nonconformities; reviewer and stakeholder feedback; adequacy of resources and competence; improvement opportunities.

Outputs (recorded as decisions): changes to the AIMS, models, thresholds or policy; risk-acceptance decisions; resource and training actions; improvement initiatives.

Minutes and decisions are retained as evidence.

Nonconformity, AI Incidents and Corrective Action

Closes ISO 42001 Clause 10.2.

Provenance and human-in-the-loop make failures detectable and traceable; this section defines what happens when one occurs.

What counts as an AI nonconformity / incident

A model breaching a performance gate; drift past its threshold; a sensitivity miss that exposes personal or special-category data; a wrongful or near-miss automated disposal/transfer; a missing or broken provenance chain; an erroneous or





hallucinated AI assertion that was relied upon. Each is logged in an AI incident register with a severity rating and an owner.

Corrective-action process

- **1. Detect and contain** - take immediate correction: quarantine or withdraw the affected output, restrict access, revert the action, place a hold. Containment first, root cause second.
- **2. Record** - capture the nonconformity, its effect, and the containment in the incident register, linked to the append-only provenance events that evidence what happened.
- **3. Root-cause analysis** - determine why (model, data, threshold, procedure, human step, infrastructure).
- **4. Corrective action** - act on the cause, not the symptom: retrain, adjust thresholds, add a detector, change a procedure, retire a model via the registry.
- **5. Verify effectiveness** - confirm the action worked and did not introduce new risk; update the risk register and model registry.
- **6. Close** - record closure; escalate systemic or high-severity incidents to the Governance Committee and into the next management review.

Competence, Awareness and Training

Closes ISO 42001 Clause 7.2 and 7.3.





The controls are only as good as the people operating them. This section defines the human capability the framework assumes.

Competence (role-based, evidenced)

Required competencies are defined per role and evidenced by training records:

- **Governance Committee** - AI-risk literacy; the legal and archival obligations; how to read risk and impact assessments and authorise or refuse a model.

- **Model Owner / Data Steward** - dataset curation, labelling discipline, evaluation-set maintenance, drift interpretation.

- **Reviewers / Curators** - the file plan and sensitivity criteria, how to read a provenance timeline and diff view, and when and how to escalate rather than wave an item through.

- **Platform Ops / SRE** - secure model serving, monitoring, backup and incident response.

Awareness

Everyone who relies on AI output is made aware of the AI policy, the principle that AI is an assistant and not an arbiter, the limits and known failure modes of the models, the transparency and provenance obligations, and the route to challenge or report an output.

Training programme

Role-based training at onboarding and on a recurring cycle, refreshed whenever a model, threshold or policy materially changes, with attendance and competence recorded as documented information.

